

Moderní kryptografie

Prof. Ing. Cyril Klimeš, CSc.

Bezpečnost

- požadavky na bezpečnost se v poslední době výrazně mění
- tradičně byla zajišťována zamezením přístupu (uzamykáním a administrativně)
- se zavedením výpočetní techniky vznikla potřeba vytvářet automatizované prostředky pro ochranu souborů a dalších informací
- použití počítačových sítí a komunikačních linek vyžaduje zajistit ochranu dat během přenosu

Definice

- **počítačová bezpečnost** – všeobecný název pro soubor prostředků, navržených k ochraně dat a maření úsilí hackerů
- **síťová bezpečnost** – opatření k ochraně dat během přenosu
- **bezpečnost Internetu** – opatření k ochraně dat během přenosu přes soubor propojených sítí
 - spočívá v opatření k odrazení, prevenci, detekci a korekci bezpečnostních hrozeb poškozujících přenos informace

Služby

- **bezpečnostní služby** – zvýšení bezpečnosti přenosu a zpracování dat
- **bezpečnostní mechanismus** – navržen k detekci, prevenci a obnově po bezpečnostním útoku, používá šifrovacích technik
- **bezpečnostní útok** – jakákoliv akce, která naruší bezpečnost informací

Ochrana výpočetních systémů

- **ochrana zdrojů** – ochrana proti neoprávněnému použití prostředků v OS
- **bezpečná komunikace** – vlastní ochrana přenášené informace
- **ověřování uživatelů** – zabezpečení, aby zprávy přicházely od ověřeného zdroje a bez modifikace

Napadení systému

- **pasivní**

- odposlech
- analýza přenosu – odkud, kam, kolik, ...

- **aktivní**

- modifikace, zadržování nebo podstrkávání zpráv
- modifikace toku dat – změna obsahu, opakování, změna pořadí, rušení, syntéza zpráv, změna adresy, změna dat, atd.
- Odepření služby

Cíl zabezpečení

- prevence pasivního útoku
- detekce aktivního útoku.

Prostředky pro zajištění bezpečnosti

- Bezpečnost
 - Bezpečnostní služby
 - Zajištění soukromí
 - Ověřování pravosti
 - Zajištění integrity
 - Kryptografické algoritmy
 - Symetrické šifrování (tajný klíč)
 - Asymetrické šifrování (tajný a veřejný klíč)
 - Otisk zprávy

Bezpečnostní mechanismy

- šifrování
- digitální podpisy
- řízení přístupu
- integrita dat
- ověřování výměny dat
- vyplňování přenosu
- řízené směrování
- ověřování třetí stranou

Bezpečnostní architektura

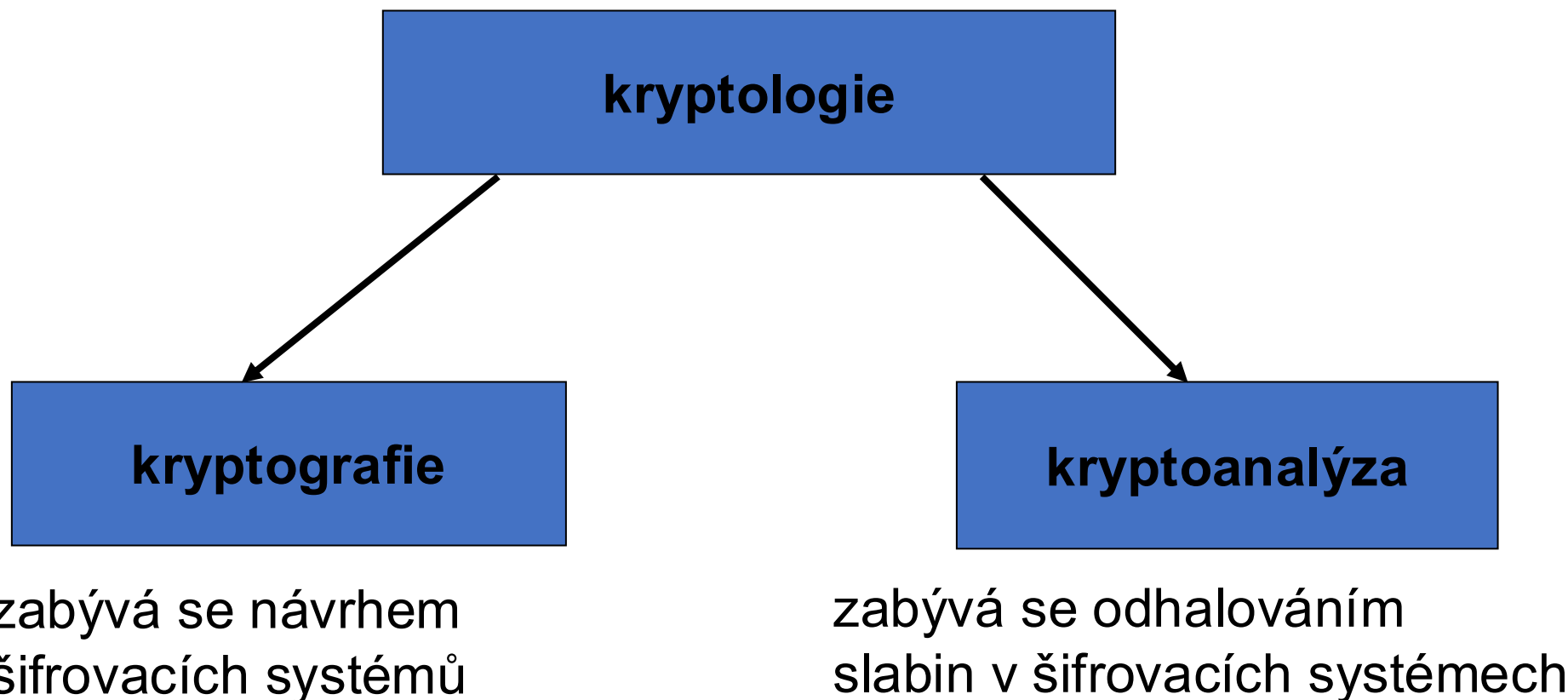
- **authentication** – ověření pravosti – ujištění, že entita je to, za co se vydává
- **access control** – řízení přístupu – zamezení neautorizovaného využívání zdrojů
- **data confidentiality** – důvěrnost dat – ochrana dat před neautorizovaným přístupem
- **data integrity** – integrita dat – ujištění, že přijatá data byla odeslána ověřenou entitou
- **non-repudiation** – nepopíratelnost – ochrana proti popření jednou z komunikujících entit

Terminologie šifrování

- **otevřený text** (plaintext)
- **šifrovaný text** (ciphertext)
- **šifra** – algoritmus pro transformaci otevřeného textu na šifrovaný
- **klíč** – parametr šifrování
- **šifrování** – převod otevřeného textu na šifrovaný
- **dešifrování** – převod šifrovaného textu na otevřený
- **kryptografie** – studium šifrovacích principů a metod
- **kryptoanalýza** – studium principů a metod pro dešifrování bez znalosti klíče
- **kryptologie** – kryptografie a kryptoanalýza

Základní pojmy

- **Kryptologie** = Kryptografie + Kryptoanalýza
- **Kryptografie** - nauka o metodách šifrování
- **Kryptoanalýza** - metody luštění šifer



Kryptografická pravidla (maxims)

shrnují zkušenosti několika tisíciletí

1. Při posuzování bezpečnosti kryptografického systému je nutné předpokládat, že protivník zná šifrovací systém (algoritmus).
2. Bezpečnost šifrovacího systému může, pokud vůbec někdo, posoudit pouze kryptoanalytik.
3. Šifrovací algoritmus by měl být „průhledný“, aby umožnil posouzení bezpečnosti. Umělé komplikace systému nemusí zvyšovat bezpečnost, naopak mohou poskytovat kryptografovi iluzorní pocit větší bezpečnosti.
4. Nikdy nepodceňujte protivníka, nikdy nepřeceňujte své schopnosti.
5. Při posuzování bezpečnosti šifrovacího systému je nutné brát v úvahu možná porušení pravidel ze strany uživatelů systému.

Možná porušení pravidel

1. Odvysílání otevřeného i odpovídajícího šifrového textu,
2. odvysílání dvou šifrových textů vzniklých šifrováním stejného otevřeného textu pomocí dvou různých klíčů,
3. odvysílání dvou šifrových textů vzniklých šifrováním dvou různých otevřených textů pomocí stejného klíče,
4. používání stereotypních začátků zpráv nebo běžných slov či frází,
5. používání krátkých klíčů nebo klíčů, které lze snadno uhádnout,
6. zanedbání přípravy otevřeného textu před šifrováním,
7. nedostatečná kontrola šifrantů.

Chyba kryptografa je často jedinou nadějí kryptoanalytika.

Základní operace šifrování

- Šifrovací operace
 - Substituce – náhrada znaků za jiné
 - Transpozice – přesun znaků (bitů) na jiné místo v kódu
- Šifra
 - Blokovaná – šifruje se po blocích pevné délky
 - Proudová – šifruje se po bitech nebo slabikách

Základní šifrovací operace

- Substituce

- Každé písmeno nebo skupina písmen je nahrazena jiným písmenem nebo skupinou písmen
- Např. Caesarova šifra – použita Caesarovými vojsky
- Jednoduše prolomitelné

- Transpozice

- Přeuspořádání písmen, ale ne překódování
- Sloupcové šifrování – otevřený text je šifrován po sloupcích různými klíčovými slovy
- Ne tak jednoduché prolomení jako u substitučních šifer.

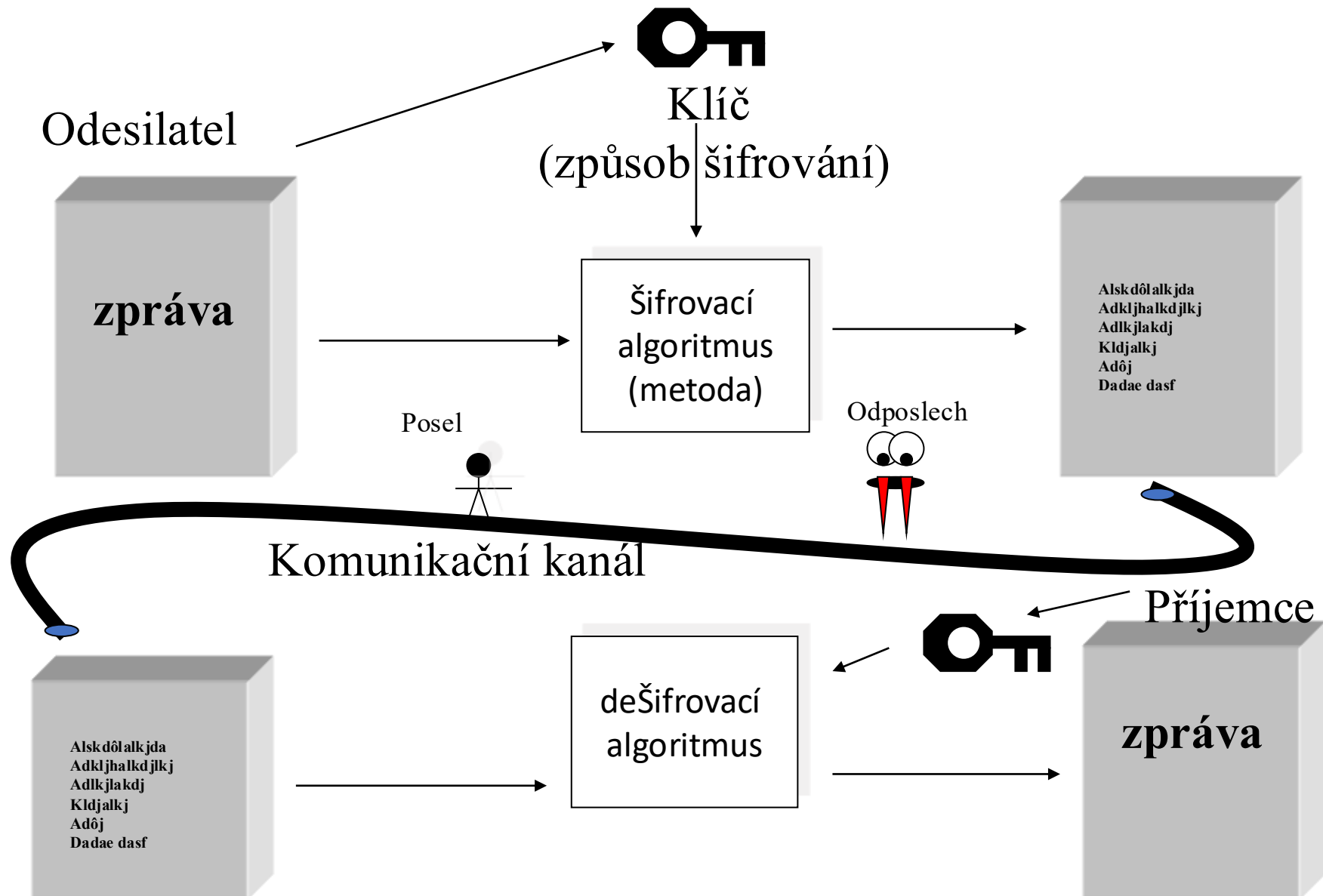
Základní šifrovací operace

- Jednorázová hesla
 - Šifrovaný text je vytvářen konverzí otevřeného textu na bitový řetězec a XOR-ován s náhodným bitovým řetězcem. Délka přenášených dat je omezena délkou řetězce (klíče)
 - Nepronikatelná šifra
 - Klíč je obtížné si pamatovat – odesílatel i příjemce musí přenášet i kopii klíče
 - Vyžaduje striktní synchronizaci mezi odesílatelem a příjemcem. Jeden chybějící bit může pomotat cokoliv

Dělení kryptografických metod

- Klasické
 - Transpoziční systém – změna pořadí znaků zprávy
 - Substituční systém – nahrazení znaků zprávy znaky šifrované abecedy
- Moderní
 - Symetrické
 - S blokovým algoritmem – pevně daná délka bloku
 - S proudovým algoritmem – délka bloku není předem známá
 - Asymetrické
 - Hybridní
 - Jednosměrné *hash* funkce

Základní schema



Kerckhoffsův princip

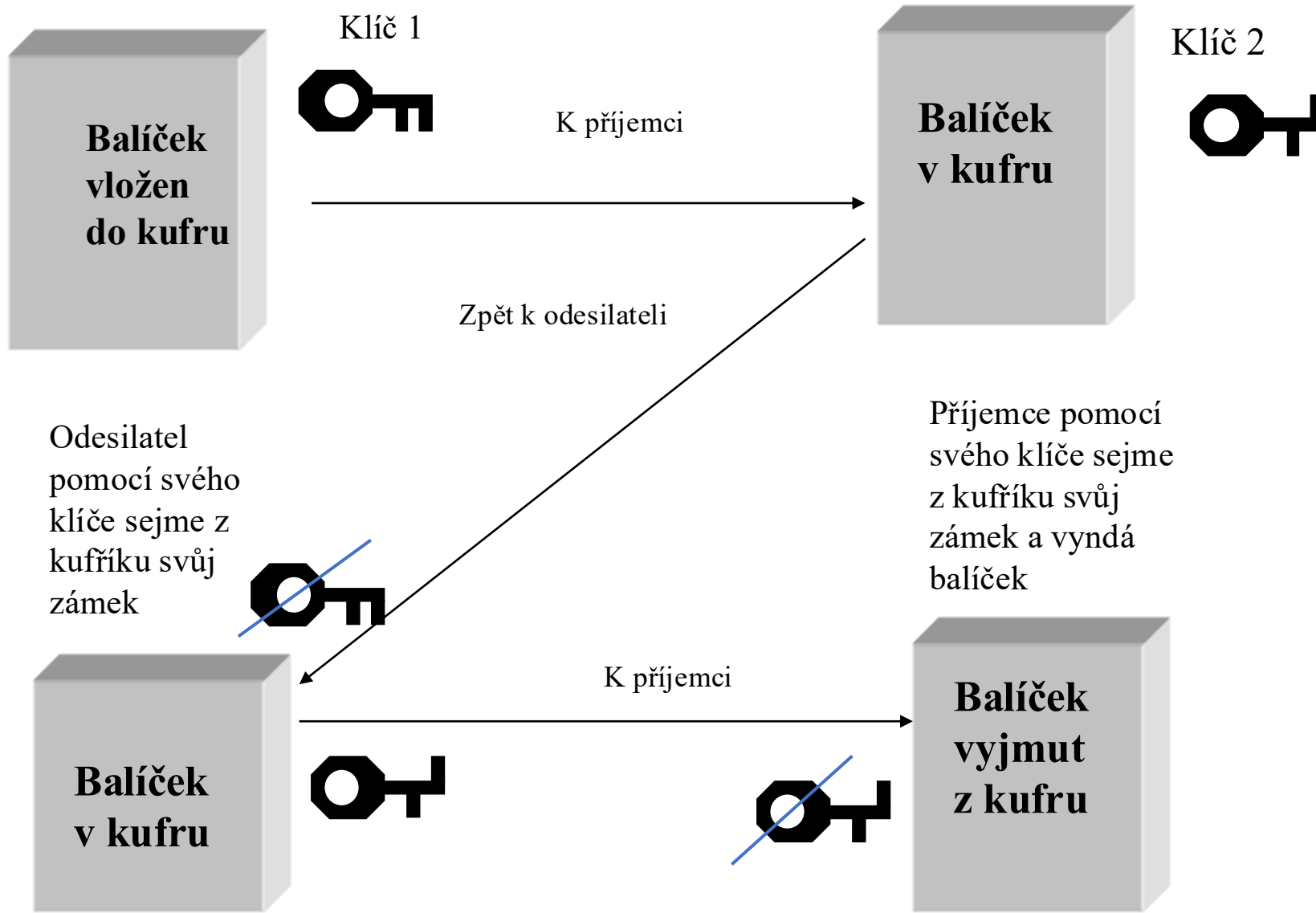
- Bezpečnost šifrovacího systému nesmí záviset na utajení algoritmu, ale pouze na utajení klíče.

Příklad doručení balíčku

- Odesílatel chce poslat balíček zabezpečený v kufru klíčem, ale nedůvěřuje nikomu a nechce dát z ruky klíč (ani příjemci). Dále neexistuje druhý klíč a kufr je nerozbitný.
- Existuje nějaké jednoduché řešení?
- Pozn. Kufr lze zamknout větším počtem zámků, ale ke každému je jen jeden klíč.

Odesílatel umístí balíček do kufru, ten zamkne svým zámkem a vyjme klíč

Příjemce zamkne kufrík svým vlastním zámkem a vyjme klíč



Prolomení šifry

- Způsob nalezení dešifrovacího klíče
- Útok hrubou silou
 - Zkoumání všech dešifrovacích klíčů
 - Získat tak smysluplný text

Třídy kryptografických algoritmů

Kryptografické algoritmy symetrické

- AES (Advanced Encryption Standard) – **FIPS 197**
- DES (Data Encryption Standard)
- 3DES (Triple DES)
- IDEA (International Data Encryption Algorithm)
- RC2 a RC4 (Rivest Cipher)
-

Kryptografické algoritmy asymetrické

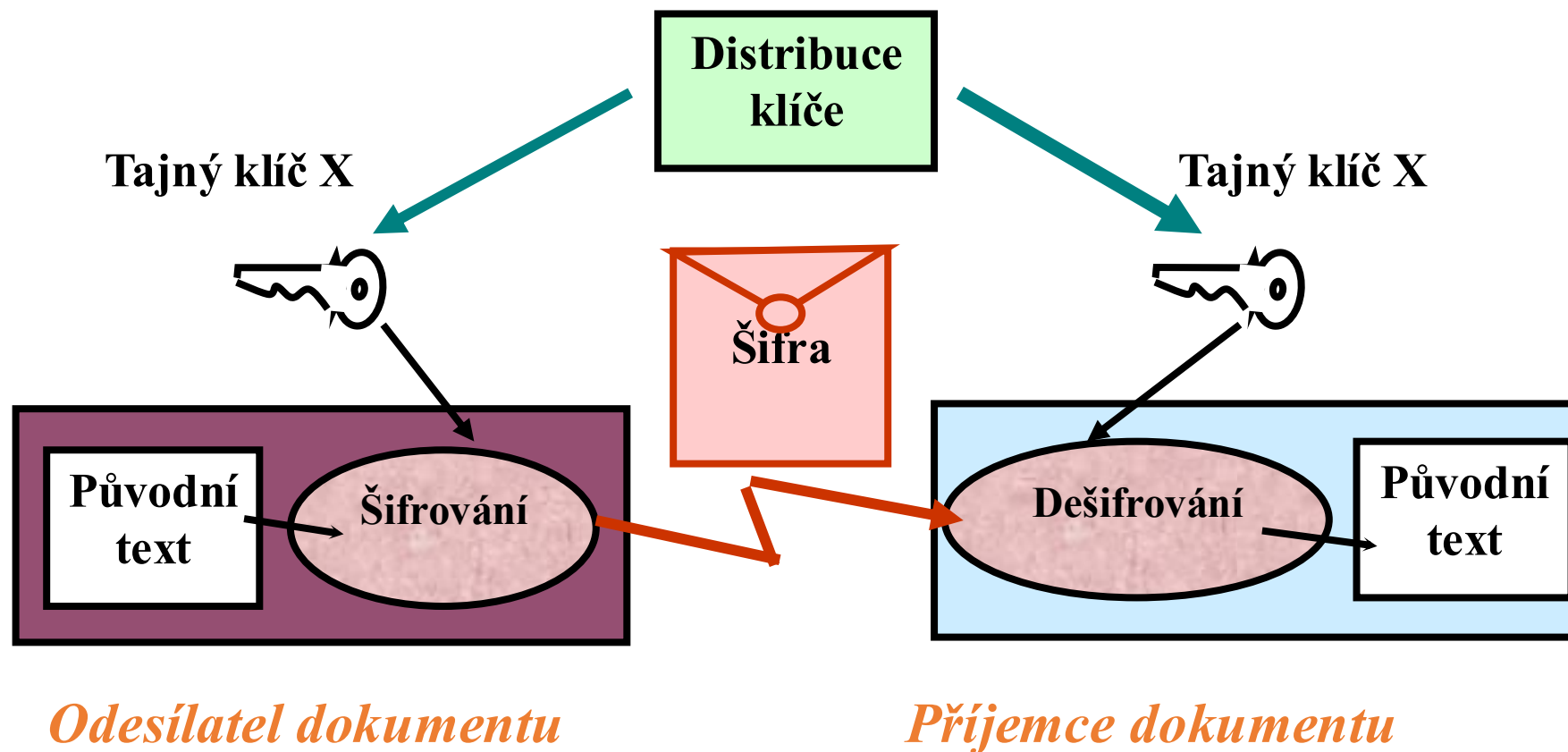
- RSA (Rivest Shamir Adleman)
- DSS (Digital Signature Standard)
- EC (Elliptic Curve)

Kryptografické systémy

- symetrická kryptografie (SK) s tajným klíčem
- asymetrická kryptografie (AK) s veřejným a soukromým klíčem
- jednocestné hash funkce (HF) - vstupní data libovolné délky jsou transformována do výstupních bloků pevné délky (charakteristika/výtah/hash)
 - s klíčem
 - bez klíče
- Kryptografické systémy zabezpečují autentičnost, integritu, důvěrnost, nepopiratelnost zodpovědnosti

Symetrická kryptografie (SK) s tajným klíčem

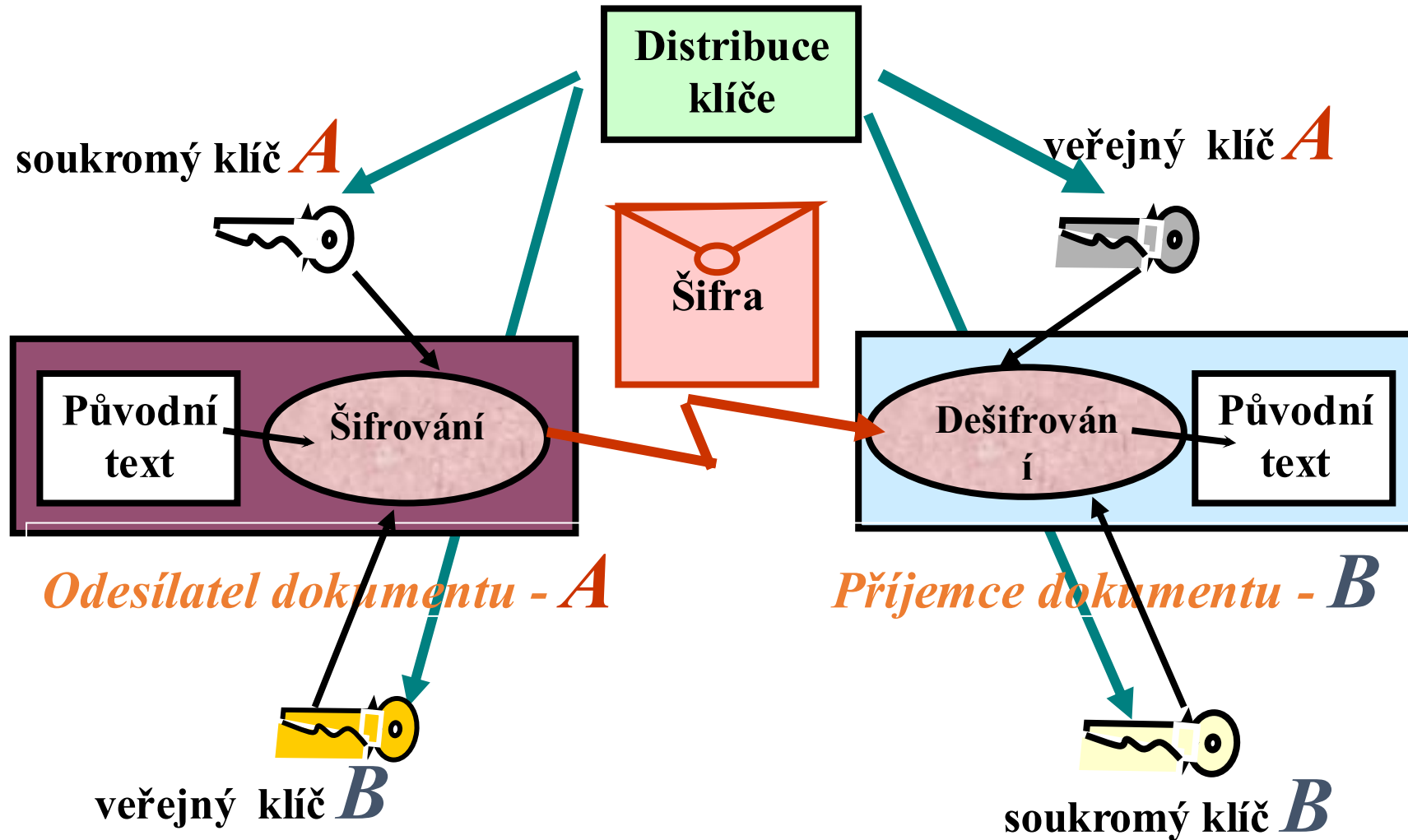
Princip symetrické kryptografie



Kryptografické algoritmy asymetrické

- Systém generuje pár klíčů, jeden pro šifrování a druhý pro dešifrování.
- Jeden klíč si ponechá a uchová v tajnosti (soukromý klíč SK) a druhý (veřejný klíč VK) publikuje na veřejném místě
- Pro šifrování a dešifrování se používá tentýž algoritmus, odesílatel a příjemce zprávy musí mít dva nepárové klíče (svůj SK a partnerův VK)
- Pro zaručení bezpečnosti výměny zprávy:
 - jeden z klíčů musí zůstat utajený
 - musí být nemožné nebo aspoň neproveditelné dešifrovat zprávu, jestliže není k dispozici další informace
 - znalost algoritmu, jednoho z klíčů a vzorku šifry musí být nedostatečné informace k odhalení druhého klíče

Princip asymetrické kryptografie



Porovnání

- Symetrická kryptografie
 - odesílatel i příjemce používají stejný klíč
 - nebo je jeden snadno odvoditelný z druhého
 - dešifrovací algoritmus je inverzí šifrovacího
 - rychlá, komplikovaná distribuce klíčů
- Asymetrická kryptografie
 - odesílatel použije jiný klíč než příjemce
 - algoritmy šifrování a dešifrování jsou obecně různé
 - pomalá, snadná distribuce klíčů, zajištění nepopiratelnosti

Rozdíly

- **Symetrická kryptografie:** menší výpočetní náročnost - vyšší výpočetní rychlost, problematické šíření klíče, dvě kopie tajemství (obě strany), pro komunikaci s n partnery je třeba mít n klíčů, pro komunikaci s neznámým partnerem je obtížné ověřit jeho identitu
- **Asymetrická kryptografie:** značná výpočetní náročnost - až 1000 x nižší výpočetní rychlost než u předchozího, pouze jedna kopie tajemství (pod vlastní kontrolou), snadné šíření klíčů (možnost uložit VK na veřejně dostupném místě), při komunikaci s neznámým partnerem lze poměrně snadno ověřit jeho identitu.